SECURE RESEARCH DATA MANAGEMENT SYSTEM

CHAPTER THREE — SYSTEM IMPLEMENTATION

Frontend screens • Backend code • Security controls • Testing • Deployment

Prepared as a runnable PHP project that does not require XAMPP

How to use this document

This document describes the Secure Research Data Management System and includes illustrative frontend screenshots, selected backend code screenshots, setup instructions, test cases and the complete source files in an appendix. The screenshots are UI mock-ups for documentation and are not evidence of a live database session. The PHP source is provided separately in the project ZIP so that it can be run and tested on a local computer.

1. System overview

The system is designed to protect university research records using password authentication, a time-limited six-digit multi-factor authentication (MFA) code, role-based access control (RBAC), encrypted file storage, audit logs, security alerts and security reports. The implementation uses PHP 8+, HTML, CSS, JavaScript-ready forms and SQLite through PDO.

- Administrator: dashboard metrics, user management, audit logs, alerts and reports.
- Researcher: upload and access research files permitted to their account.
- Viewer: read/download access according to the configured access policy.
- Security: password hashes, session checks, CSRF tokens, encrypted stored files and audit events.

2. Application structure

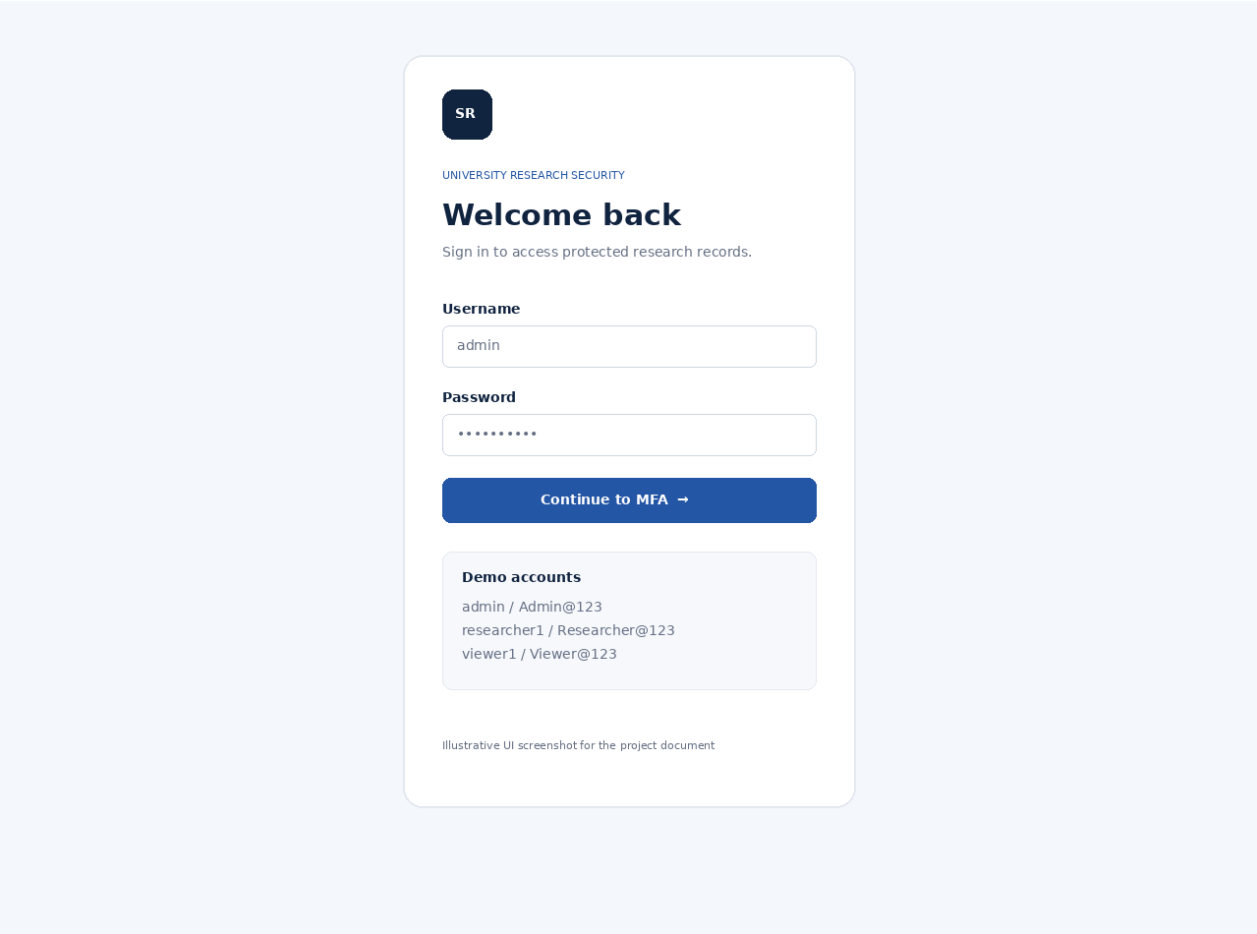
The source project is organized into the following key files:

- index.php — entry point and redirect.
- login.php / logout.php — password login, demo MFA and sign-out.
- dashboard.php — role-aware summary.
- files.php — file upload, encryption, listing and download/decryption.
- audit.php — administrator audit event filters.
- alerts.php — security alert review and resolution.
- reports.php — login, file and alert metrics.
- users.php — create users, assign roles and activate/deactivate accounts.
- config/database.php — SQLite schema and initial demo accounts.
- includes/functions.php — sessions, CSRF, role checks, encryption and audit helpers.
- assets/css/style.css — responsive frontend presentation.

3. Frontend screenshots

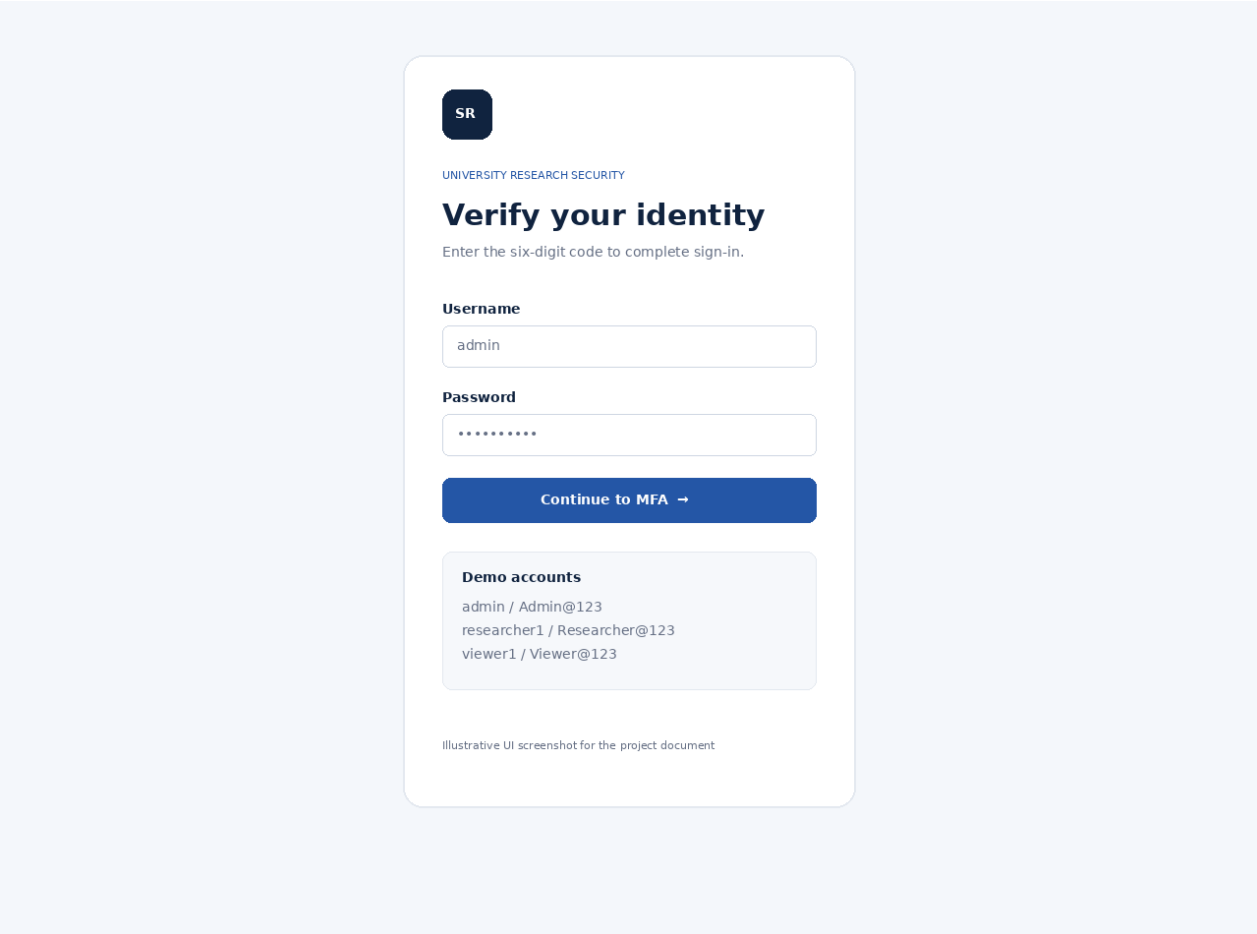
The following screenshots illustrate the intended screens and their main elements. The example records and counters shown are sample display data for the document.

Figure 3.2.1 — Login page



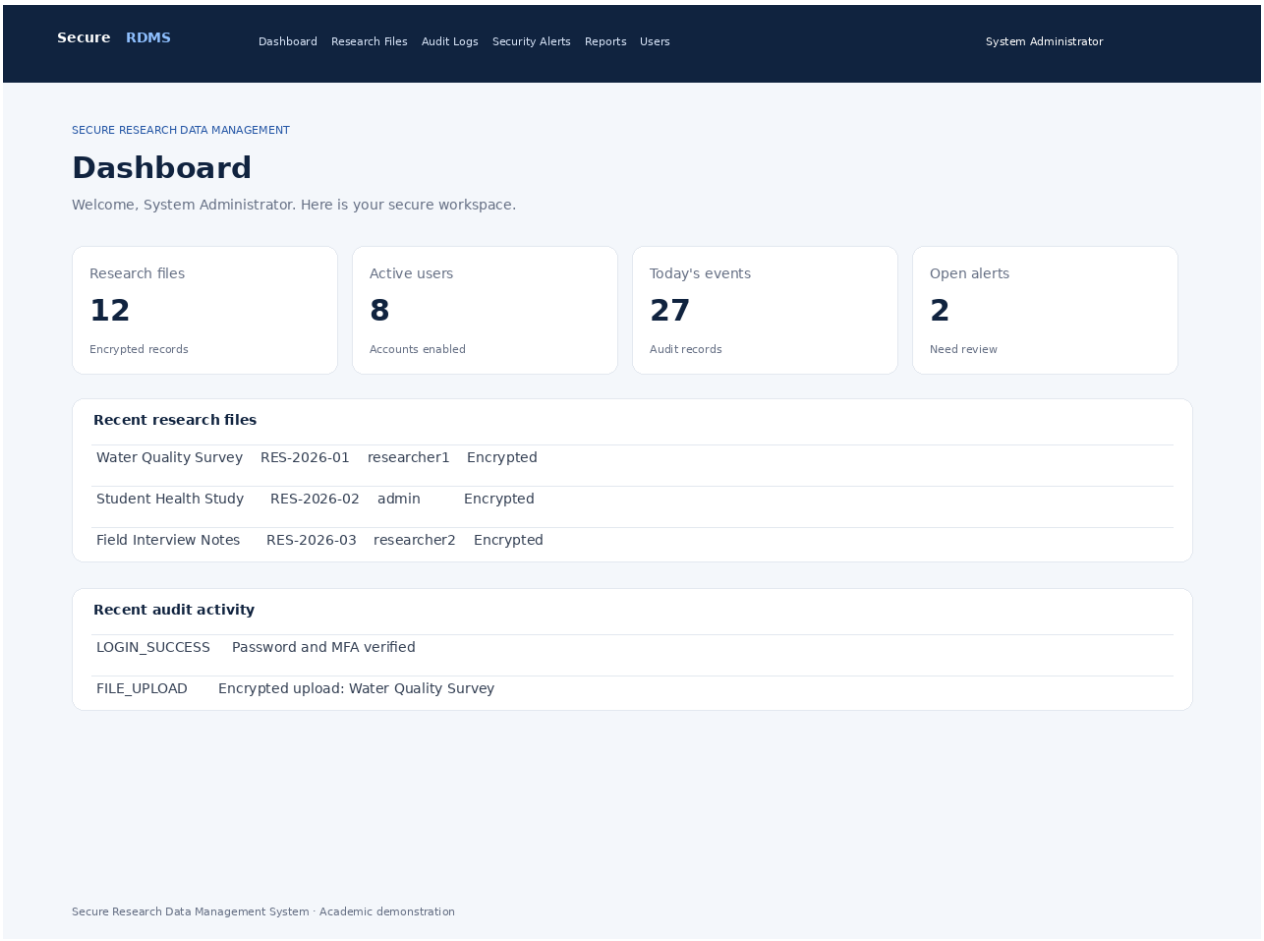
Username and password are validated first. Passwords are stored as hashes, not plain text.

Figure 3.2.2 — MFA challenge



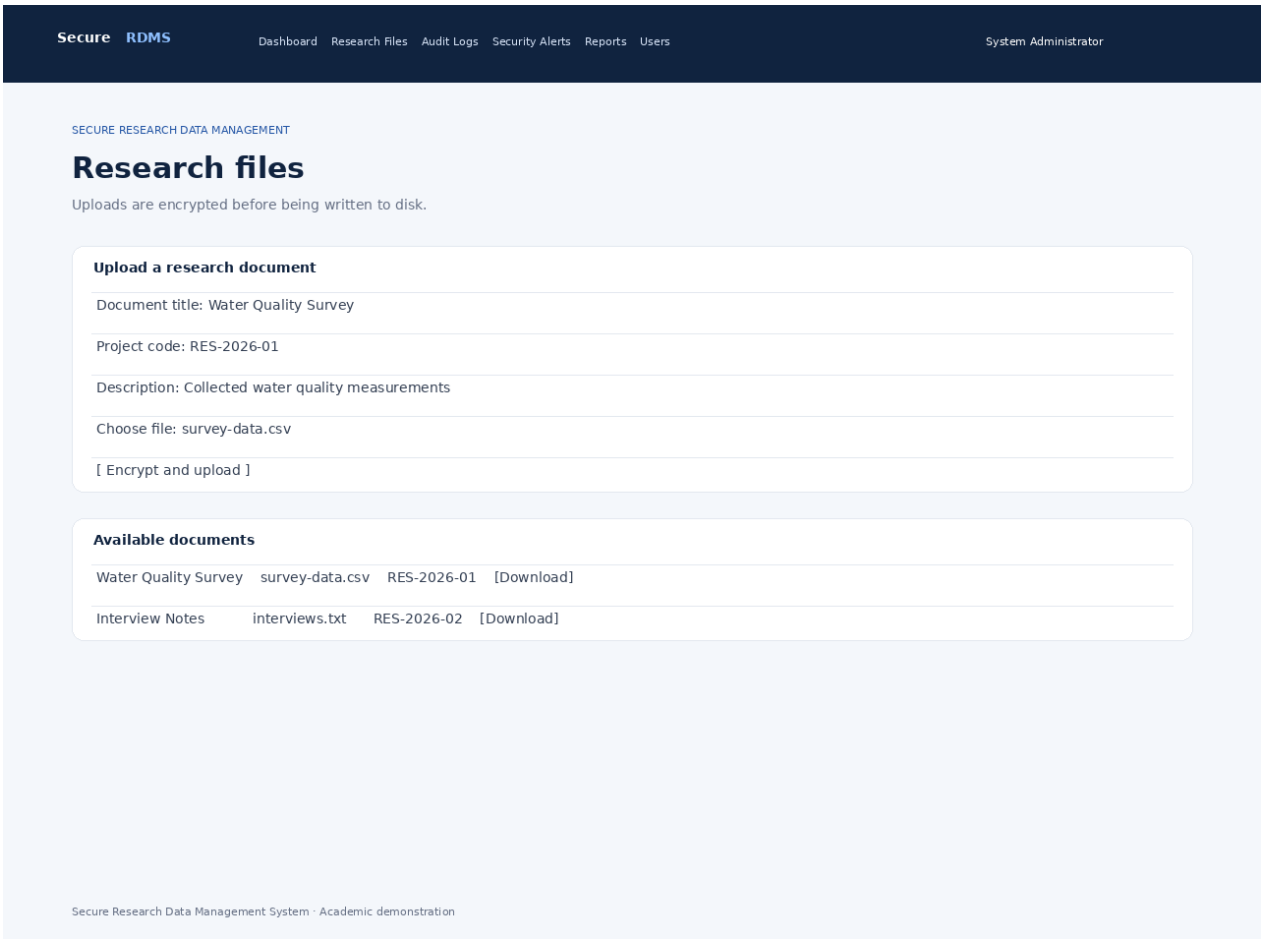
After a valid password, a six-digit one-time code is created with a five-minute expiry. The code is shown on-screen in this local demo.

Figure 3.2.3 — Administrator dashboard



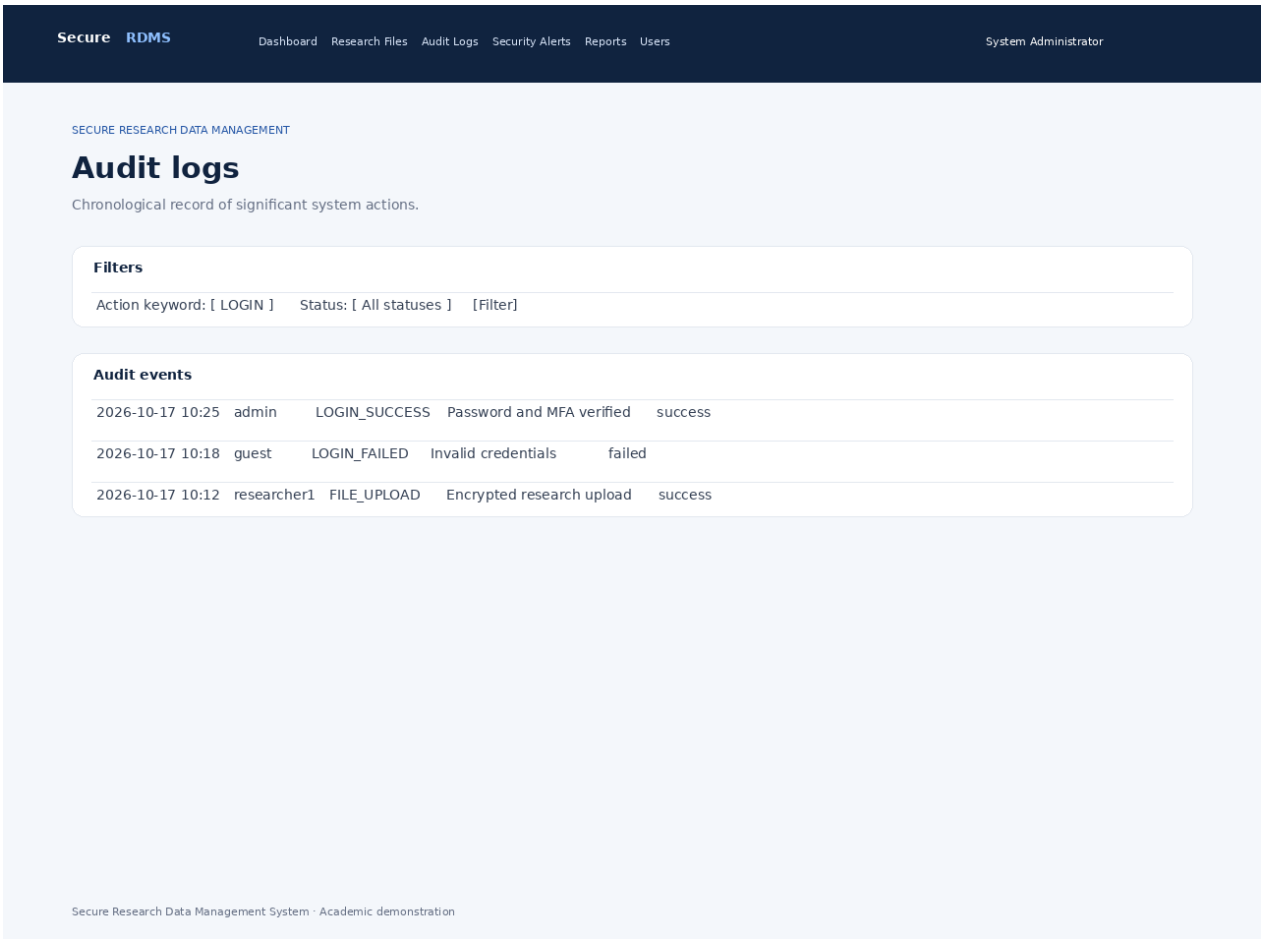
The dashboard summarizes research files, active users, today’s events and open alerts, followed by recent files and audit activity.

Figure 3.2.4 — Research file management



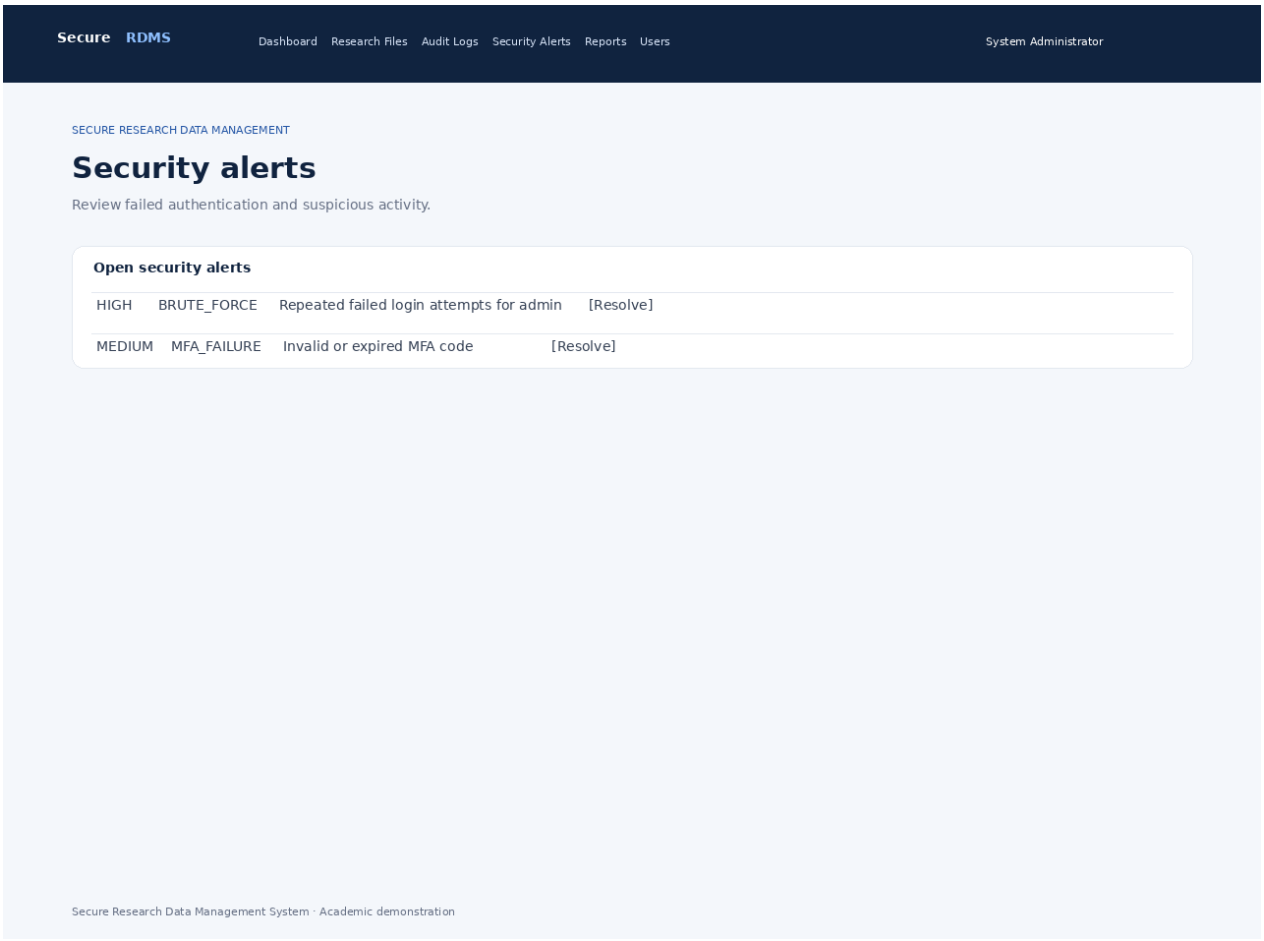
Researchers and administrators can upload a titled file and metadata. Stored file bytes are encrypted before writing to the uploads folder.

Figure 3.2.5 — Audit logs



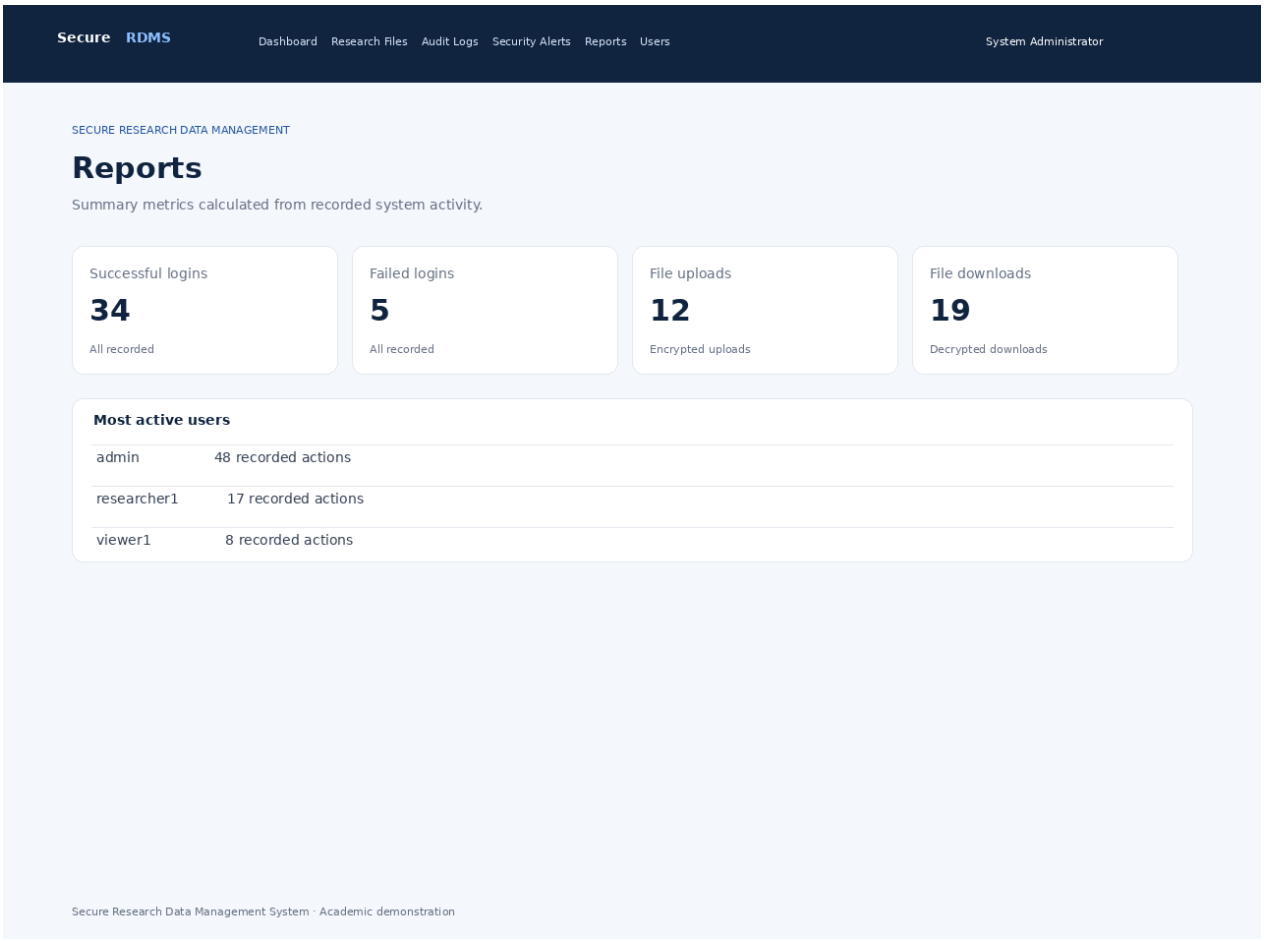
Administrators can filter events by action keyword and success/failure status.

Figure 3.2.6 — Security alerts



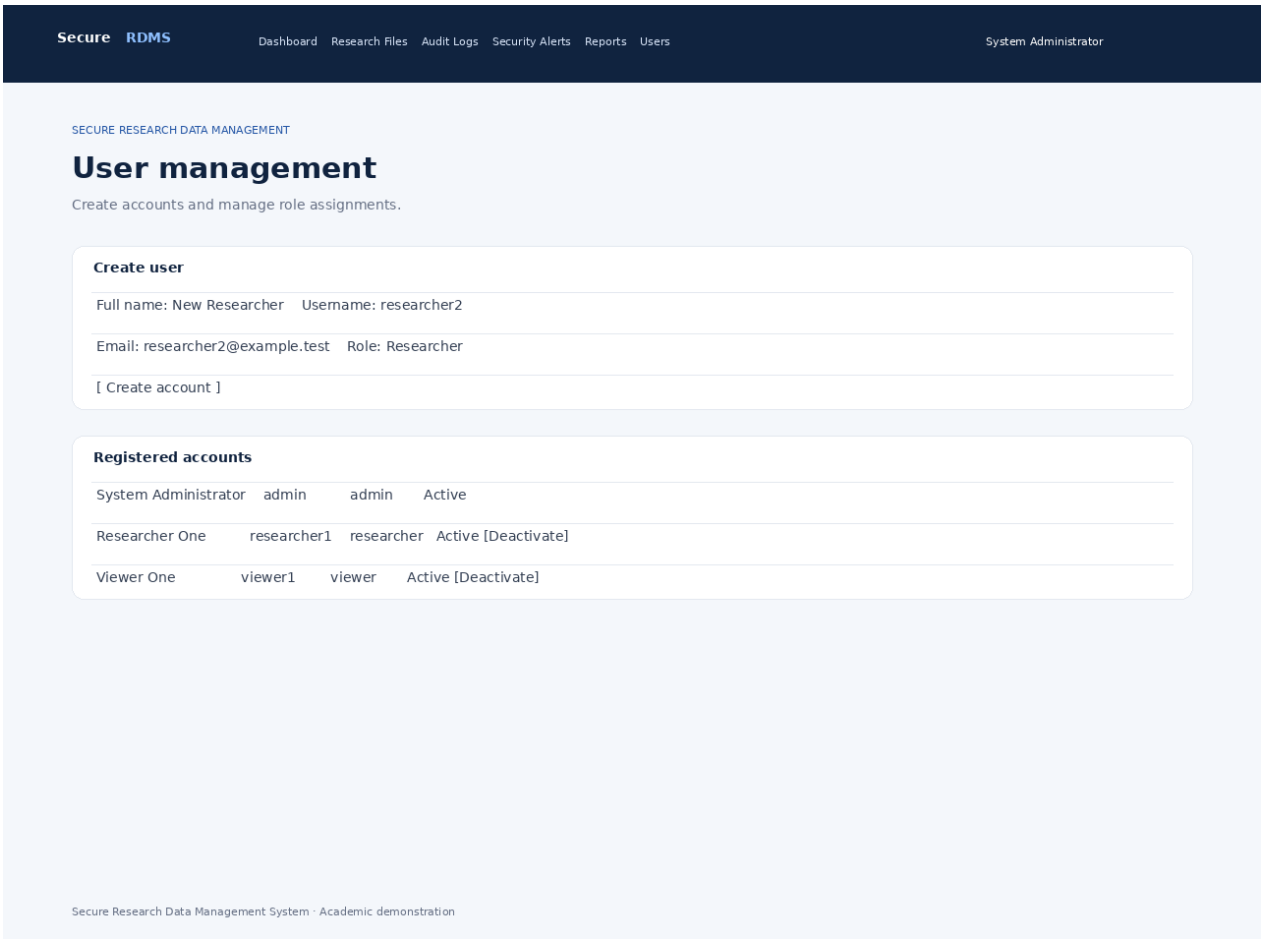
Suspicious authentication activity is represented as alerts with severity and a resolve action.

Figure 3.2.7 — Security reports



Aggregated counts summarize successful/failed logins, file events, MFA failures and open alerts.

Figure 3.2.8 — User management



Administrators can create users, choose a role and activate or deactivate accounts.

4. Backend implementation and code screenshots

These images show excerpts from the actual PHP source files included in the project bundle. The full code is also reproduced as text in Appendix A so it can be copied, searched and edited.

Figure 3.3.1 — Authentication and MFA code

AUTHENTICATION & MFA — login.php

```php
<?php
require_once __DIR__.'/includes/functions.php';
if (!empty($_SESSION['user_id'])) { header('Location: dashboard.php'); exit; }
$error='';
if ($_SERVER['REQUEST_METHOD']==='POST') { verifyCsrf();
 if (($_POST['step']??'credentials')==='credentials') {
  $username=trim($_POST['username']??''); $password=$_POST['password']??'';
  $s=$pdo->prepare('SELECT * FROM users WHERE username=? AND is_active=1'); $s->execute([$username]);
    $user=$s->fetch();
  $a=$pdo->prepare('INSERT INTO login_attempts(username,success) VALUES(?,?)');
    $a->execute([$username,($user && password_verify($password,$user['password_hash']))?1:0]);
  $fail=$pdo->prepare("SELECT COUNT(*) FROM login_attempts WHERE username=? AND success=0 AND
    attempted_at >= datetime('now','-15 minutes')"); $fail->execute([$username]);
    $failCount=(int)$fail->fetchColumn();
  if ($user && password_verify($password,$user['password_hash']) && $failCount<5) {
   $code=(string)random_int(100000,999999); $ins=$pdo->prepare("INSERT INTO
    mfa_codes(user_id,code_hash,expires_at) VALUES(?,?,datetime('now','+5 minutes'))");
    $ins->execute([$user['id'],password_hash($code,PASSWORD_DEFAULT)]);
   $_SESSION['mfa_user']=$user['id']; $_SESSION['mfa_code_demo']=$code;
    logAudit('CREDENTIALS_ACCEPTED','Password verified; MFA issued','success',$user['id'],$username);
    header('Location: login.php?mfa=1'); exit;
  }
  logAudit('LOGIN_FAILED','Invalid credentials or temporary lockout','failed',null,$username);
    if($failCount>=5) createSecurityAlert($user['id']??null,'BRUTE_FORCE','Five or more failed login
    attempts for '.$username,'high'); $error='Invalid credentials or too many failed attempts.';
 } else {
  $id=(int)($_SESSION['mfa_user']??0); $code=trim($_POST['code']??''); $s=$pdo->prepare("SELECT * FROM
    mfa_codes WHERE user_id=? AND used=0 AND expires_at>datetime('now') ORDER BY id DESC");
    $s->execute([$id]); $row=$s->fetch();
  if($row && password_verify($code,$row['code_hash'])) { $pdo->prepare('UPDATE mfa_codes SET used=1 WHERE
     id=?')->execute([$row['id']]); $s=$pdo->prepare('SELECT * FROM users WHERE id=? AND is_active=1');
    $s->execute([$id]); $u=$s->fetch(); if($u){ session_regenerate_id(true);
    $_SESSION['user_id']=$u['id']; $_SESSION['username']=$u['username'];
    $_SESSION['full_name']=$u['full_name']; $_SESSION['role']=$u['role'];
    unset($_SESSION['mfa_user'],$_SESSION['mfa_code_demo']); $pdo->prepare('UPDATE users SET
    last_login=CURRENT_TIMESTAMP WHERE id=?')->execute([$u['id']]); logAudit('LOGIN_SUCCESS','Password
    and MFA verified'); header('Location: dashboard.php'); exit; } }
  logAudit('MFA_FAILED','Invalid or expired MFA code','failed',$id?:null);
    createSecurityAlert($id?:null,'MFA_FAILURE','Invalid or expired MFA code','medium'); $error='The code
     is invalid or has expired. Start again.'; unset($_SESSION['mfa_user'],$_SESSION['mfa_code_demo']);
 }
}
pageStart('Sign in'); ?>
<section class="auth-wrap"><div class="auth-card"><div class="brand-mark">SR</div><p
    class="eyebrow">UNIVERSITY RESEARCH SECURITY</p><h1><?=isset($_GET['mfa'])?'Verify your
    identity':'Welcome back'?></h1><p class="muted"><?=isset($_GET['mfa'])?'Enter the six-digit code to
    complete sign-in.':'Sign in to access protected research records.'?></p>
<?php if($error):?><div class="alert danger"><?=h($error)?></div><?php endif;?>
<?php if(isset($_GET['mfa']) && !empty($_SESSION['mfa_user'])): ?><form method="post"><input
    type="hidden" name="csrf" value="<?=h(csrfToken())?>"><input type="hidden" name="step"
    value="mfa"><label for="code">6-digit verification code</label><input id="code" name="code"
    inputmode="numeric" pattern="[0-9]{6}" maxlength="6" placeholder="000000" required autofocus><button
    class="btn primary full">Verify and continue</button></form><div class="demo-code">Demo OTP:
    <strong><?=h($_SESSION['mfa_code_demo']??'')?></strong><small>Displayed only for local demonstration;
     expires in 5 minutes.</small></div><?php else: ?><form method="post"><input type="hidden"
    name="csrf" value="<?=h(csrfToken())?>"><input type="hidden" name="step" value="credentials"><label
    for="username">Username</label><input id="username" name="username" autocomplete="username" required
    autofocus><label for="password">Password</label><input id="password" type="password" name="password"
    autocomplete="current-password" required><button class="btn primary full">Continue to MFA
    <span>→</span></button></form><div class="demo-accounts"><strong>Demo accounts</strong><p>admin /
    Admin@123</p><p>researcher1 / Researcher@123</p><p>viewer1 / Viewer@123</p></div><?php
    endif;?></div></section>
<?php pageEnd(); ?>
```

The login controller checks the password hash, creates a one-time code, validates its expiry and establishes the authenticated session.

Figure 3.3.2 — Shared security helpers

BACKEND SECURITY HELPERS includes/functions.php

```php
<?php
if (session_status() !== PHP_SESSION_ACTIVE) { session_name('RDMSSESSID'); session_start(); }
require_once __DIR__ . '/../config/database.php';
function h($v): string { return htmlspecialchars((string)$v, ENT_QUOTES, 'UTF-8'); }
function logAudit(string $action, string $details='', string $status='success', ?int $userId=null,
    ?string $username=null): void {
 global $pdo; $uid=$userId ?? ($_SESSION['user_id'] ?? null); $uname=$username ?? ($_SESSION['username']
    ?? 'guest');
 $s=$pdo->prepare('INSERT INTO audit_logs(user_id,username,action,details,ip_address,user_agent,status)
    VALUES(?,?,?,?,?,?,?)');
 $s-
    >execute([$uid,$uname,$action,$details,$_SERVER['REMOTE_ADDR']??'local',substr($_SERVER['HTTP_USER_AG
    ENT']??'unknown',0,250),$status]);
}
function createSecurityAlert(?int $userId,string $type,string $message,string $severity='medium'): void {
     global $pdo; $s=$pdo->prepare('INSERT INTO security_alerts(user_id,alert_type,message,severity)
    VALUES(?,?,?,?)'); $s->execute([$userId,$type,$message,$severity]); }
function requireLogin(): void { if (empty($_SESSION['user_id'])) { header('Location: login.php'); exit; } }
function requireRole($roles): void { requireLogin(); if (!in_array($_SESSION['role'],(array)$roles,true))
     { logAudit('UNAUTHORIZED_ACCESS','Attempted restricted page','failed'); header('Location:
    dashboard.php?error=access_denied'); exit; } }
function csrfToken(): string { if (empty($_SESSION['csrf'])) $_SESSION['csrf']=bin2hex(random_bytes(32));
     return $_SESSION['csrf']; }
function verifyCsrf(): void { if ($_SERVER['REQUEST_METHOD']==='POST' &&
    !hash_equals($_SESSION['csrf']??'', $_POST['csrf']??'')) { http_response_code(400); exit('Invalid
    request token. Return and try again.'); } }
function encryptFile(string $source,string $dest): void { $data=file_get_contents($source);
    $key=hash('sha256', getenv('RDMS_ENCRYPTION_KEY') ?: 'local-demo-key-change-before-deployment',
    true); $iv=random_bytes(16); $cipher=openssl_encrypt($data,'AES-256-CBC',$key,OPENSSL_RAW_DATA,$iv);
    if ($cipher===false || file_put_contents($dest,$iv.$cipher)===false) throw new
    RuntimeException('Could not encrypt file.'); }
function decryptFile(string $path): string|false { $data=file_get_contents($path); if ($data===false ||
    strlen($data)<17) return false; $key=hash('sha256', getenv('RDMS_ENCRYPTION_KEY') ?: 'local-demo-key-
    change-before-deployment', true); return
    openssl_decrypt(substr($data,16),'AES-256-CBC',$key,OPENSSL_RAW_DATA,substr($data,0,16)); }
function pageStart(string $title): void { $active=basename($_SERVER['PHP_SELF']); echo '<!doctype
    html><html lang="en"><head><meta charset="utf-8"><meta name="viewport" content="width=device-
    width,initial-scale=1"><title>'.h($title).' | Secure RDMS</title><link rel="stylesheet"
    href="assets/css/style.css"></head><body><header class="topbar"><a class="brand"
    href="dashboard.php">Secure <span>RDMS</span></a>'; if (!empty($_SESSION['user_id'])) { echo '<nav><a
     href="dashboard.php">Dashboard</a><a href="files.php">Research Files</a>'; if
    ($_SESSION['role']==='admin') echo '<a href="audit.php">Audit Logs</a><a href="alerts.php">Security
    Alerts</a><a href="reports.php">Reports</a><a href="users.php">Users</a>'; echo '</nav><div
    class="identity">'.h($_SESSION['full_name']).'<small>'.h(ucfirst($_SESSION['role'])).'</small> <a
    class="logout" href="logout.php">Logout</a></div>'; } echo '</header><main class="container">'; }
function pageEnd(): void { echo '</main><footer>Secure Research Data Management System · Academic
    demonstration</footer></body></html>'; }
function notice(): void { if(isset($_GET['error'])) echo '<div class="alert
    danger">'.h($_GET['error']==='access_denied'?'Access denied. Your role cannot open that
    page.':$_GET['error']).'</div>'; if(isset($_GET['message'])) echo '<div class="alert
    success">'.h($_GET['message']).'</div>'; }
```

The shared helpers provide HTML escaping, audit logging, role enforcement, CSRF verification and file encryption/decryption.

Figure 3.3.3 — Research file workflow

FILE ENCRYPTION WORKFLOW files.php

```php
<?php require_once __DIR__.'/includes/functions.php'; requireLogin(); $msg=''; $err='';
if($_SERVER['REQUEST_METHOD']==='POST'){verifyCsrf(); if(($_POST['action']??'')==='upload') {
    if(!in_array($_SESSION['role'],['admin','researcher'],true)){http_response_code(403);exit('Your role
    cannot upload files.');} $f=$_FILES['research_file']??null; $title=trim($_POST['title']??'');
    if(!$title||!$f||$f['error']!==UPLOAD_ERR_OK||$f['size']>10*1024*1024){$err='Enter a title and select
     a file smaller than 10 MB.';} else { $dir=__DIR__.'/uploads';
    if(!is_dir($dir))mkdir($dir,0700,true); $stored=bin2hex(random_bytes(16)).'.enc'; try {
    encryptFile($f['tmp_name'],$dir.'/'.$stored); $s=$pdo->prepare('INSERT INTO research_data(title,descr
    iption,filename,original_filename,file_path,file_size,mime_type,uploaded_by,project_code)
    VALUES(?,?,?,?,?,?,?,?,?)'); $s-
    >execute([$title,trim($_POST['description']??''),$stored,basename($f['name']),$dir.'/'.$stored,(int)$
    f['size'],$f['type']??'application/octet-
    stream',$_SESSION['user_id'],trim($_POST['project_code']??'')]); logAudit('FILE_UPLOAD','Encrypted
    upload: '.$title); header('Location: files.php?message='.urlencode('File encrypted and uploaded
    successfully.'));exit; } catch(Throwable $e){$err='Upload failed. Check the uploads folder
    permissions.';} } } }
if(isset($_GET['download'])) {
    $s=in_array($_SESSION['role'],['admin','viewer'],true)?$pdo->prepare('SELECT * FROM research_data
    WHERE id=?'):$pdo->prepare('SELECT * FROM research_data WHERE id=? AND uploaded_by=?'); in_array($_SE
    SSION['role'],['admin','viewer'],true)?$s->execute([(int)$_GET['download']]):$s-
    >execute([(int)$_GET['download'],$_SESSION['user_id']]); $r=$s->fetch();
    if(!$r){logAudit('UNAUTHORIZED_ACCESS','Attempted download of unavailable
    file','failed');http_response_code(404);exit('File not found or access denied.');}
    $plain=decryptFile($r['file_path']); if($plain===false)exit('Unable to decrypt file.');
    logAudit('FILE_DOWNLOAD','Decrypted download: '.$r['title']); header('Content-Type:
    application/octet-stream');header('Content-Disposition: attachment;
    filename="'.str_replace('"','',basename($r['original_filename'])).'"');header('Content-Length:
    '.strlen($plain));echo $plain;exit; }
pageStart('Research files'); notice(); ?><div class="page-heading"><div><p class="eyebrow">DATA
    REPOSITORY</p><h1>Research files</h1><p class="muted">Uploads are encrypted before being written to
    disk.</p></div></div><?php if($err):?><div class="alert danger"><?=h($err)?></div><?php endif;?>
<?php if(in_array($_SESSION['role'],['admin','researcher'],true)):?><div class="panel"><h2>Upload a
    research document</h2><form method="post" enctype="multipart/form-data" class="form-grid"><input
    type="hidden" name="csrf" value="<?=h(csrfToken())?>"><input type="hidden" name="action"
    value="upload"><div><label>Document title *</label><input name="title"
    required></div><div><label>Project code</label><input name="project_code" placeholder="e.g.
    RES-2026-01"></div><div class="span-2"><label>Description</label><textarea name="description"
    rows="2"></textarea></div><div class="span-2"><label>Choose file (maximum 10 MB) *</label><input
    type="file" name="research_file" required></div><div class="span-2"><button class="btn
    primary">Encrypt and upload</button></div></form></div><?php endif;?>
<div class="panel"><h2>Available documents</h2><div class="table-
    wrap"><table><thead><tr><th>Title</th><th>Original
    filename</th><th>Project</th><th>Uploaded</th><th>Action</th></tr></thead><tbody><?php
    $s=in_array($_SESSION['role'],['admin','viewer'],true)?$pdo->query('SELECT * FROM research_data ORDER
     BY id DESC'):$pdo->prepare('SELECT * FROM research_data WHERE uploaded_by=? ORDER BY id DESC');
    if(!in_array($_SESSION['role'],['admin','viewer'],true))$s->execute([$_SESSION['user_id']]);
    $rows=$s->fetchAll();if(!$rows)echo '<tr><td colspan="5" class="empty">No files
    available.</td></tr>';foreach($rows as $r)echo '<tr><td>'.h($r['title']).'</td><td>'.h($r['original_f
    ilename']).'</td><td>'.h($r['project_code']?:'—').'</td><td>'.h($r['created_at']).'</td><td><a
    class="btn small secondary" href="files.php?download='.(int)$r['id'].'">Download</a></td></tr>';?></t
    body></table></div></div><?php pageEnd(); ?>
```

The file controller validates uploads, encrypts the file before storage, stores metadata and decrypts authorized downloads.

Figure 3.3.4 — Database initialization

DATABASE SCHEMA — config/database.php

```php
<?php
// SQLite database bootstrap. Requires PHP PDO_SQLite extension.
$base = dirname(__DIR__);
if (!is_dir($base . '/storage')) mkdir($base . '/storage', 0700, true);
$pdo = new PDO('sqlite:' . $base . '/storage/rdms.sqlite');
$pdo->setAttribute(PDO::ATTR_ERRMODE, PDO::ERRMODE_EXCEPTION);
$pdo->setAttribute(PDO::ATTR_DEFAULT_FETCH_MODE, PDO::FETCH_ASSOC);
$pdo->exec('PRAGMA foreign_keys = ON');
$schema = [
"CREATE TABLE IF NOT EXISTS users (id INTEGER PRIMARY KEY AUTOINCREMENT, username TEXT UNIQUE NOT NULL,
    email TEXT UNIQUE NOT NULL, password_hash TEXT NOT NULL, full_name TEXT NOT NULL, role TEXT NOT NULL
    CHECK(role IN ('admin','researcher','viewer')), is_active INTEGER NOT NULL DEFAULT 1, created_at TEXT
     DEFAULT CURRENT_TIMESTAMP, last_login TEXT)",
"CREATE TABLE IF NOT EXISTS research_data (id INTEGER PRIMARY KEY AUTOINCREMENT, title TEXT NOT NULL,
    description TEXT, filename TEXT NOT NULL, original_filename TEXT NOT NULL, file_path TEXT NOT NULL,
    file_size INTEGER, mime_type TEXT, uploaded_by INTEGER NOT NULL, project_code TEXT, created_at TEXT
    DEFAULT CURRENT_TIMESTAMP, FOREIGN KEY(uploaded_by) REFERENCES users(id))",
"CREATE TABLE IF NOT EXISTS audit_logs (id INTEGER PRIMARY KEY AUTOINCREMENT, user_id INTEGER, username
    TEXT, action TEXT NOT NULL, details TEXT, ip_address TEXT, user_agent TEXT, status TEXT DEFAULT
    'success', created_at TEXT DEFAULT CURRENT_TIMESTAMP)",
"CREATE TABLE IF NOT EXISTS mfa_codes (id INTEGER PRIMARY KEY AUTOINCREMENT, user_id INTEGER NOT NULL,
    code_hash TEXT NOT NULL, expires_at TEXT NOT NULL, used INTEGER DEFAULT 0, FOREIGN KEY(user_id)
    REFERENCES users(id))",
"CREATE TABLE IF NOT EXISTS security_alerts (id INTEGER PRIMARY KEY AUTOINCREMENT, user_id INTEGER,
    alert_type TEXT NOT NULL, message TEXT NOT NULL, severity TEXT DEFAULT 'medium', resolved INTEGER
    DEFAULT 0, created_at TEXT DEFAULT CURRENT_TIMESTAMP, FOREIGN KEY(user_id) REFERENCES users(id))",
"CREATE TABLE IF NOT EXISTS login_attempts (id INTEGER PRIMARY KEY AUTOINCREMENT, username TEXT,
    attempted_at TEXT DEFAULT CURRENT_TIMESTAMP, success INTEGER DEFAULT 0)"
];
foreach ($schema as $sql) $pdo->exec($sql);
$count = (int)$pdo->query('SELECT COUNT(*) FROM users')->fetchColumn();
if (!$count) {
  $seed = $pdo->prepare('INSERT INTO users(username,email,password_hash,full_name,role) VALUES(?,?,?,?,?)');
  foreach ([['admin','admin@example.test','Admin@123','System
    Administrator','admin'],['researcher1','researcher@example.test','Researcher@123','Researcher
    One','researcher'],['viewer1','viewer@example.test','Viewer@123','Viewer One','viewer']] as $u)
    $seed->execute([$u[0],$u[1],password_hash($u[2], PASSWORD_DEFAULT),$u[3],$u[4]]);
}
```

PDO creates the SQLite tables and seeds the three local demonstration accounts on first run.

5. Database and security controls

Control	Implementation	Purpose
Authentication	Password hashes + MFA code	Verify account holder
RBAC	admin / researcher / viewer	Restrict protected pages and actions
File protection	AES-256-CBC encryption before disk write	Protect stored research file contents
Audit trail	Logins, file events, access failures and account actions	Support investigation and accountability
Security alerts	Failed authentication and suspicious login patterns	Flag events for administrator review
Reports	Aggregated event counts	Summarize system activity

Important security note: this is an academic demonstration. AES-CBC alone does not authenticate ciphertext; production deployments should use authenticated encryption such as AES-GCM, store keys in a proper key-management service, enforce HTTPS, configure secure cookies, strengthen rate limiting and obtain a security review. The demo fallback key must not be used for real research data.

6. How to run without XAMPP

1. Install PHP 8.1 or newer. Enable the PDO_SQLite, SQLite3 and OpenSSL extensions.
2. Extract secure_rdms_project.zip to a folder, for example C:\projects\secure_rdms.
3. Open PowerShell or Terminal in that folder.
4. Run: php -S 127.0.0.1:8000
5. Open http://127.0.0.1:8000 in a browser.
6. Sign in with one of the demo accounts below, then enter the one-time code shown on the MFA page.

Demo accounts

Role	Username	Password
Administrator	admin	Admin@123
Researcher	researcher1	Researcher@123
Viewer	viewer1	Viewer@123

The accounts are for local demonstration only. Change them before sharing the application or using it with real data.

Troubleshooting

Error: could not find driver: The PHP installation used by the terminal does not have PDO_SQLite enabled. Enable/install pdo_sqlite and restart the built-in server.

Page cannot connect: Confirm the command php -S 127.0.0.1:8000 is still running and visit the same address.

Upload fails: Check that the uploads directory is writable and that the file is under 10 MB.

Demo OTP expired: Return to the login page and repeat the password step to generate a new code.

7. Test plan

Test	Expected result	How to check
Valid credentials and MFA	Dashboard opens	Use a demo account and current OTP
Wrong password	Error is shown and event is logged	Enter an incorrect password
Wrong/expired OTP	MFA error and security event	Enter a random code
Upload a small text file	Encrypted .enc file is saved	Upload through Research Files
Download uploaded file	Original contents are returned	Use Download while authorized
Open admin page as researcher	Access denied and audit event	Sign in as researcher and open audit.php
Create a user	Account appears in user table	Use Users while admin
Resolve an alert	Alert status changes to resolved	Use Security Alerts while admin
Reports page	Counts match recorded events	Generate events then open Reports

8. Deployment and limitations

- PHP built-in server is for local development/demo use, not public production hosting.
- The OTP is displayed on screen rather than sent by email or SMS.

- The encryption key fallback is only for local testing. Set RDMS_ENCRYPTION_KEY to a long random secret before testing non-demo data.
- The current implementation uses AES-256-CBC for alignment with the supplied chapter. For production, prefer authenticated encryption (AES-GCM) and managed keys.
- Use HTTPS, secure session cookie settings, strict file-type validation, backup/restore procedures, monitoring and an independent security review before any real deployment.

Appendix A — Complete source code

The source files below are included verbatim from the runnable project folder. Code blocks are split across pages as needed. For a ready-to-run folder, use the accompanying ZIP archive.

README.md

```
# Secure Research Data Management System (RDMS)

A PHP web application for a university research repository, with password authentication, a time-limited
demo MFA code, role-based access, encrypted file storage, audit logs, security alerts and summary
reports.

## Run without XAMPP

1. Install **PHP 8.1 or newer**. Make sure these PHP extensions are enabled: `pdo_sqlite`, `sqlite3`, and
 `openssl`. XAMPP is not required.
2. Open a terminal in this `secure_rdms` folder.
3. Start the PHP built-in server:
  - Windows PowerShell: `php -S 127.0.0.1:8000`
  - macOS/Linux: `php -S 127.0.0.1:8000`
4. Open `http://127.0.0.1:8000` in your browser.
5. Sign in using one of the accounts below. After the password is accepted, enter the demo OTP shown on
the MFA page.

## Demo accounts

| Role | Username | Password |
|---|---|---|
| Administrator | `admin` | `Admin@123` |
| Researcher | `researcher1` | `Researcher@123` |
| Viewer | `viewer1` | `Viewer@123` |

These credentials are for local demonstration only. Change them before any shared or production
deployment.

## Project layout

- `index.php` — redirects to login/dashboard
- `login.php`, `logout.php` — password + MFA demo flow and sign-out
- `dashboard.php` — role-aware dashboard
- `files.php` — upload, encrypt, list and decrypt/download research files
- `audit.php` — administrator audit log with filters
- `alerts.php` — review and resolve security alerts
- `reports.php` — security metrics and activity summaries
- `users.php` — create users, assign roles and activate/deactivate accounts
- `config/database.php` — SQLite schema and demo seed accounts
- `includes/functions.php` — sessions, CSRF, RBAC, encryption and audit helpers
- `assets/css/style.css` — frontend styling
```

- `uploads/` — encrypted `.enc` files
- `storage/` — generated SQLite database

Important limitations and security notes

- The app creates its database on first request. If PHP reports `could not find driver`, enable/install the `pdo_sqlite` extension for the PHP installation used by the command `php`.
- The OTP is displayed on screen only for demonstration; it is not sent by email/SMS.
- The encryption key fallback is a local-demo key. Set the `RDMS_ENCRYPTION_KEY` environment variable to a long random secret before testing with non-demo data. For real deployment, use a managed key service and authenticated encryption (for example AES-GCM), HTTPS, backups, rate limiting, secure session cookies, stricter file validation and independent security review.
- This is an academic demonstrator, not a production-ready service. Audit logs are useful records but are not tamper-proof against a server administrator.
- PHP's built-in server is intended for local development/demo use, not internet-facing production hosting.

index.php

```
<?php
require_once __DIR__.'/includes/functions.php';
header('Location: '.(!empty($_SESSION['user_id'])?'dashboard.php':'login.php')); exit;
```

login.php

```
<?php
require_once __DIR__.'/includes/functions.php';
if (!empty($_SESSION['user_id'])) { header('Location: dashboard.php'); exit; }
$error='';
if ($_SERVER['REQUEST_METHOD']==='POST') { verifyCsrf();
 if (($_POST['step']??'credentials')==='credentials') {
  $username=trim($_POST['username']??''); $password=$_POST['password']??'';
  $s=$pdo->prepare('SELECT * FROM users WHERE username=? AND is_active=1'); $s->execute([$username]);
$user=$s->fetch();
  $a=$pdo->prepare('INSERT INTO login_attempts(username,success) VALUES(?,?)');
$a->execute([$username,($user && password_verify($password,$user['password_hash']))?1:0]);
  $fail=$pdo->prepare("SELECT COUNT(*) FROM login_attempts WHERE username=? AND success=0 AND
attempted_at >= datetime('now','-15 minutes')"); $fail->execute([$username]);
$failCount=(int)$fail->fetchColumn();
  if ($user && password_verify($password,$user['password_hash']) && $failCount<5) {
   $code=(string)random_int(100000,999999); $ins=$pdo->prepare("INSERT INTO
mfa_codes(user_id,code_hash,expires_at) VALUES(?,?,datetime('now','+5 minutes'))");
$ins->execute([$user['id'],password_hash($code,PASSWORD_DEFAULT)]);
   $_SESSION['mfa_user']=$user['id']; $_SESSION['mfa_code_demo']=$code;
logAudit('CREDENTIALS_ACCEPTED','Password verified; MFA issued','success',$user['id'],$username);
header('Location: login.php?mfa=1'); exit;
  }
  logAudit('LOGIN_FAILED','Invalid credentials or temporary lockout','failed',null,$username);
if($failCount>=5) createSecurityAlert($user['id']??null,'BRUTE_FORCE','Five or more failed login attempts
 for '.$username,'high'); $error='Invalid credentials or too many failed attempts.';
 } else {
  $id=(int)($_SESSION['mfa_user']??0); $code=trim($_POST['code']??''); $s=$pdo->prepare("SELECT * FROM
mfa_codes WHERE user_id=? AND used=0 AND expires_at>datetime('now') ORDER BY id DESC");
$s->execute([$id]); $row=$s->fetch();
  if($row && password_verify($code,$row['code_hash'])) { $pdo->prepare('UPDATE mfa_codes SET used=1 WHERE
 id=?')->execute([$row['id']]); $s=$pdo->prepare('SELECT * FROM users WHERE id=? AND is_active=1');
$s->execute([$id]); $u=$s->fetch(); if($u){ session_regenerate_id(true); $_SESSION['user_id']=$u['id'];
$_SESSION['username']=$u['username']; $_SESSION['full_name']=$u['full_name'];
$_SESSION['role']=$u['role']; unset($_SESSION['mfa_user'],$_SESSION['mfa_code_demo']);
$pdo->prepare('UPDATE users SET last_login=CURRENT_TIMESTAMP WHERE id=?')->execute([$u['id']]);
logAudit('LOGIN_SUCCESS','Password and MFA verified'); header('Location: dashboard.php'); exit; } }
  logAudit('MFA_FAILED','Invalid or expired MFA code','failed',$id?:null);
createSecurityAlert($id?:null,'MFA_FAILURE','Invalid or expired MFA code','medium'); $error='The code is
invalid or has expired. Start again.'; unset($_SESSION['mfa_user'],$_SESSION['mfa_code_demo']);
 }
}
pageStart('Sign in'); ?>
```

```
<section class="auth-wrap"><div class="auth-card"><div class="brand-mark">SR</div><p
class="eyebrow">UNIVERSITY RESEARCH SECURITY</p><h1><?=isset($_GET['mfa'])?'Verify your
identity':'Welcome back'?></h1><p class="muted"><?=isset($_GET['mfa'])?'Enter the six-digit code to
complete sign-in.':'Sign in to access protected research records.'?></p>
<?php if($error):?><div class="alert danger"><?=h($error)?></div><?php endif;?>
<?php if(isset($_GET['mfa']) && !empty($_SESSION['mfa_user'])): ?><form method="post"><input
type="hidden" name="csrf" value="<?=h(csrfToken())?>"><input type="hidden" name="step" value="mfa"><label
 for="code">6-digit verification code</label><input id="code" name="code" inputmode="numeric"
pattern="[0-9]{6}" maxlength="6" placeholder="000000" required autofocus><button class="btn primary
full">Verify and continue</button></form><div class="demo-code">Demo OTP:
<strong><?=h($_SESSION['mfa_code_demo']??'')?></strong><small>Displayed only for local demonstration;
expires in 5 minutes.</small></div><?php else: ?><form method="post"><input type="hidden" name="csrf"
value="<?=h(csrfToken())?>"><input type="hidden" name="step" value="credentials"><label
for="username">Username</label><input id="username" name="username" autocomplete="username" required
autofocus><label for="password">Password</label><input id="password" type="password" name="password"
autocomplete="current-password" required><button class="btn primary full">Continue to MFA
<span>→</span></button></form><div class="demo-accounts"><strong>Demo accounts</strong><p>admin /
Admin@123</p><p>researcher1 / Researcher@123</p><p>viewer1 / Viewer@123</p></div><?php
endif;?></div></section>
<?php pageEnd(); ?>
```

logout.php

```
<?php require_once __DIR__.'/includes/functions.php'; if(!empty($_SESSION['user_id']))
logAudit('LOGOUT','User signed out'); $_SESSION=[]; session_destroy(); header('Location:
login.php?message='.urlencode('You have signed out.')); exit;
```

dashboard.php

```
<?php require_once __DIR__.'/includes/functions.php'; requireLogin(); pageStart('Dashboard'); notice();
$admin=$_SESSION['role']==='admin'; $files=(int)$pdo->query('SELECT COUNT(*) FROM
research_data')->fetchColumn(); $users=(int)$pdo->query('SELECT COUNT(*) FROM users WHERE
is_active=1')->fetchColumn(); $alerts=(int)$pdo->query('SELECT COUNT(*) FROM security_alerts WHERE
resolved=0')->fetchColumn(); $events=(int)$pdo->query("SELECT COUNT(*) FROM audit_logs WHERE
date(created_at)=date('now')")->fetchColumn(); ?>
<div class="page-heading"><div><p class="eyebrow">OVERVIEW</p><h1>Dashboard</h1><p class="muted">Welcome,
 <?=h($_SESSION['full_name'])?>. Here is your secure workspace.</p></div><span class="role-
chip"><?=h(strtoupper($_SESSION['role']))?></span></div>
<div class="stats-grid"><div class="stat-card"><span>Research
files</span><strong><?=$files?></strong><small>Encrypted records</small></div><?php if($admin):?><div
class="stat-card"><span>Active users</span><strong><?=$users?></strong><small>Accounts
enabled</small></div><div class="stat-card"><span>Today's
events</span><strong><?=$events?></strong><small>Audit records</small></div><div class="stat-
card"><span>Open alerts</span><strong><?=$alerts?></strong><small>Need review</small></div><?php
endif;?></div>
<div class="panel"><div class="panel-head"><div><h2>Recent research files</h2><p class="muted">Files
visible to your account.</p></div><a class="btn secondary" href="files.php">Open file
manager</a></div><div class="table-wrap"><table><thead><tr><th>Title</th><th>Project</th><th>Uploaded
by</th><th>Date</th><th>Status</th></tr></thead><tbody><?php
$q=in_array($_SESSION['role'],['admin','viewer'],true)?$pdo->query('SELECT r.*,u.username FROM
research_data r JOIN users u ON u.id=r.uploaded_by ORDER BY r.id DESC LIMIT 6'):$pdo->prepare('SELECT
r.*,u.username FROM research_data r JOIN users u ON u.id=r.uploaded_by WHERE r.uploaded_by=? ORDER BY
r.id DESC LIMIT 6');
if(!in_array($_SESSION['role'],['admin','viewer'],true))$q->execute([$_SESSION['user_id']]);
$rows=$q->fetchAll(); if(!$rows) echo '<tr><td colspan="5" class="empty">No research files yet. Upload a
sample document to begin.</td></tr>'; foreach($rows as $r) echo '<tr><td>'.h($r['title']).'</td><td>'.h($
r['project_code']?:'—').'</td><td>'.h($r['username']).'</td><td>'.h($r['created_at']).'</td><td><span
class="status">Encrypted</span></td></tr>';?></tbody></table></div></div>
<?php if($admin):?><div class="panel"><div class="panel-head"><div><h2>Recent audit activity</h2><p
class="muted">Latest recorded security events.</p></div><a href="audit.php">View audit logs
→</a></div><?php foreach($pdo->query('SELECT * FROM audit_logs ORDER BY id DESC LIMIT 4') as $e) echo
'<div class="event-row"><span class="event-dot"></span><div><strong>'.h($e['action']).'</strong><p>'.h($e
['details']).'</p></div><time>'.h($e['created_at']).'</time></div>';?></div><?php endif;?>
<?php pageEnd(); ?>
```

files.php

```
<?php require_once __DIR__.'/includes/functions.php'; requireLogin(); $msg=''; $err='';
if($_SERVER['REQUEST_METHOD']==='POST'){verifyCsrf(); if(($_POST['action']??'')==='upload') {
if(!in_array($_SESSION['role'],['admin','researcher'],true)){http_response_code(403);exit('Your role
cannot upload files.');} $f=$_FILES['research_file']??null; $title=trim($_POST['title']??'');
if(!$title||!$f||$f['error']!==UPLOAD_ERR_OK||$f['size']>10*1024*1024){$err='Enter a title and select a
file smaller than 10 MB.';} else { $dir=__DIR__.'/uploads'; if(!is_dir($dir))mkdir($dir,0700,true);
$stored=bin2hex(random_bytes(16)).'.enc'; try { encryptFile($f['tmp_name'],$dir.'/'.$stored);
$s=$pdo->prepare('INSERT INTO research_data(title,description,filename,original_filename,file_path,file_s
ize,mime_type,uploaded_by,project_code) VALUES(?,?,?,?,?,?,?,?,?)'); $s-
>execute([$title,trim($_POST['description']??''),$stored,basename($f['name']),$dir.'/'.$stored,(int)$f['s
ize'],$f['type']??'application/octet-stream',$_SESSION['user_id'],trim($_POST['project_code']??'')]);
logAudit('FILE_UPLOAD','Encrypted upload: '.$title); header('Location:
files.php?message='.urlencode('File encrypted and uploaded successfully.'));exit; } catch(Throwable
$e){$err='Upload failed. Check the uploads folder permissions.';} } } }
if(isset($_GET['download'])) {
$s=in_array($_SESSION['role'],['admin','viewer'],true)?$pdo->prepare('SELECT * FROM research_data WHERE
id=?'):$pdo->prepare('SELECT * FROM research_data WHERE id=? AND uploaded_by=?'); in_array($_SESSION['rol
e'],['admin','viewer'],true)?$s->execute([(int)$_GET['download']]):$s-
>execute([(int)$_GET['download'],$_SESSION['user_id']]); $r=$s->fetch();
if(!$r){logAudit('UNAUTHORIZED_ACCESS','Attempted download of unavailable
file','failed');http_response_code(404);exit('File not found or access denied.');}
$plain=decryptFile($r['file_path']); if($plain===false)exit('Unable to decrypt file.');
logAudit('FILE_DOWNLOAD','Decrypted download: '.$r['title']); header('Content-Type: application/octet-
stream');header('Content-Disposition: attachment;
filename="'.str_replace('"','',basename($r['original_filename'])).'"');header('Content-Length:
'.strlen($plain));echo $plain;exit; }
pageStart('Research files'); notice(); ?><div class="page-heading"><div><p class="eyebrow">DATA
REPOSITORY</p><h1>Research files</h1><p class="muted">Uploads are encrypted before being written to
disk.</p></div></div><?php if($err):?><div class="alert danger"><?=h($err)?></div><?php endif;?>
<?php if(in_array($_SESSION['role'],['admin','researcher'],true)):?><div class="panel"><h2>Upload a
research document</h2><form method="post" enctype="multipart/form-data" class="form-grid"><input
type="hidden" name="csrf" value="<?=h(csrfToken())?>"><input type="hidden" name="action"
value="upload"><div><label>Document title *</label><input name="title" required></div><div><label>Project
 code</label><input name="project_code" placeholder="e.g. RES-2026-01"></div><div
class="span-2"><label>Description</label><textarea name="description" rows="2"></textarea></div><div
class="span-2"><label>Choose file (maximum 10 MB) *</label><input type="file" name="research_file"
required></div><div class="span-2"><button class="btn primary">Encrypt and
upload</button></div></form></div><?php endif;?>
```

```
<div class="panel"><h2>Available documents</h2><div class="table-
wrap"><table><thead><tr><th>Title</th><th>Original
filename</th><th>Project</th><th>Uploaded</th><th>Action</th></tr></thead><tbody><?php
$s=in_array($_SESSION['role'],['admin','viewer'],true)?$pdo->query('SELECT * FROM research_data ORDER BY
id DESC'):$pdo->prepare('SELECT * FROM research_data WHERE uploaded_by=? ORDER BY id DESC');
if(!in_array($_SESSION['role'],['admin','viewer'],true))$s->execute([$_SESSION['user_id']]);
$rows=$s->fetchAll();if(!$rows)echo '<tr><td colspan="5" class="empty">No files
available.</td></tr>';foreach($rows as $r)echo '<tr><td>'.h($r['title']).'</td><td>'.h($r['original_filen
ame']).'</td><td>'.h($r['project_code']?:'—').'</td><td>'.h($r['created_at']).'</td><td><a class="btn
small secondary"
href="files.php?download='.(int)$r['id'].'">Download</a></td></tr>';?></tbody></table></div></div><?php
pageEnd(); ?>
```

audit.php

```
<?php require_once __DIR__.'/includes/functions.php'; requireRole('admin');
$action=trim($_GET['action']??'');$status=trim($_GET['status']??'');$sql='SELECT * FROM audit_logs WHERE
1=1';$args=[];if($action!==''){$sql.=' AND action LIKE
?';$args[]='%'.$action.'%';}if(in_array($status,['success','failed'],true)){$sql.=' AND
status=?';$args[]=$status;}$sql.=' ORDER BY id DESC LIMIT
250';$s=$pdo->prepare($sql);$s->execute($args);pageStart('Audit logs');?><div class="page-
heading"><div><p class="eyebrow">ACCOUNTABILITY</p><h1>Audit logs</h1><p class="muted">Chronological
record of significant system actions.</p></div></div><div class="panel"><form class="filter-row"><input
name="action" placeholder="Filter action keyword" value="<?=h($action)?>"><select name="status"><option
value="">All statuses</option><option value="success"
<?=$status==='success'?'selected':''?>>Success</option><option value="failed"
<?=$status==='failed'?'selected':''?>>Failed</option></select><button class="btn
primary">Filter</button></form><div class="table-wrap"><table><thead><tr><th>Time</th><th>User</th><th>Ac
tion</th><th>Details</th><th>IP</th><th>Status</th></tr></thead><tbody><?php foreach($s as $r)echo '<tr><
td>'.h($r['created_at']).'</td><td>'.h($r['username']).'</td><td>'.h($r['action']).'</td><td>'.h($r['deta
ils']).'</td><td>'.h($r['ip_address']).'</td><td><span class="status '.($r['status']==='failed'?'failed':
'').'">'.h($r['status']).'</span></td></tr>';?></tbody></table></div></div><?php pageEnd(); ?>
```

alerts.php

```
<?php require_once __DIR__.'/includes/functions.php';requireRole('admin');if($_SERVER['REQUEST_METHOD']==
='POST'){verifyCsrf();$id=(int)($_POST['id']??0);$pdo->prepare('UPDATE security_alerts SET resolved=1
WHERE id=?')->execute([$id]);logAudit('ALERT_RESOLVED','Resolved alert #'.$id);header('Location:
alerts.php?message='.urlencode('Alert marked as resolved.'));exit;}pageStart('Security
alerts');notice();?><div class="page-heading"><div><p class="eyebrow">THREAT MONITORING</p><h1>Security
alerts</h1><p class="muted">Review failed authentication and suspicious activity.</p></div></div><div
class="panel"><div class="table-wrap"><table><thead><tr><th>Time</th><th>Type</th><th>Message</th><th>Sev
erity</th><th>Status</th><th>Action</th></tr></thead><tbody><?php $rows=$pdo->query('SELECT * FROM
security_alerts ORDER BY resolved ASC,id DESC')->fetchAll();if(!$rows)echo '<tr><td colspan="6"
class="empty">No security alerts have been generated.</td></tr>';foreach($rows as $r){echo '<tr><td>'.h($
r['created_at']).'</td><td>'.h($r['alert_type']).'</td><td>'.h($r['message']).'</td><td><span
class="severity '.h($r['severity']).'">'.h($r['severity']).'</span></td><td>'.($r['resolved']?'Resolved':
'<strong>Open</strong>').'</td><td>';if(!$r['resolved'])echo '<form method="post"><input type="hidden"
name="csrf" value="'.h(csrfToken()).'"><input type="hidden" name="id" value="'.(int)$r['id'].'"><button
class="btn small secondary">Resolve</button></form>';echo
'</td></tr>';}?></tbody></table></div></div><?php pageEnd(); ?>
```

reports.php

```
<?php require_once __DIR__.'/includes/functions.php';requireRole('admin');pageStart('Security
reports');$count=function($sql){global $pdo;return (int)$pdo->query($sql)->fetchColumn();};?><div
class="page-heading"><div><p class="eyebrow">SECURITY ANALYTICS</p><h1>Reports</h1><p
class="muted">Summary metrics calculated from recorded system activity.</p></div></div><div class="stats-
grid"><div class="stat-card"><span>Successful logins</span><strong><?=$count("SELECT COUNT(*) FROM
audit_logs WHERE action='LOGIN_SUCCESS'")?></strong></div><div class="stat-card"><span>Failed
logins</span><strong><?=$count("SELECT COUNT(*) FROM audit_logs WHERE
action='LOGIN_FAILED'")?></strong></div><div class="stat-card"><span>File
uploads</span><strong><?=$count("SELECT COUNT(*) FROM audit_logs WHERE
action='FILE_UPLOAD'")?></strong></div><div class="stat-card"><span>File
downloads</span><strong><?=$count("SELECT COUNT(*) FROM audit_logs WHERE
action='FILE_DOWNLOAD'")?></strong></div><div class="stat-card"><span>MFA
failures</span><strong><?=$count("SELECT COUNT(*) FROM audit_logs WHERE
```

```
action='MFA_FAILED'")?></strong></div><div class="stat-card"><span>Open
alerts</span><strong><?=$count('SELECT COUNT(*) FROM security_alerts WHERE
resolved=0')?></strong></div></div><div class="panel"><h2>Most active users</h2><div class="table-
wrap"><table><thead><tr><th>Username</th><th>Recorded actions</th></tr></thead><tbody><?php
foreach($pdo->query('SELECT username,COUNT(*) AS total FROM audit_logs GROUP BY username ORDER BY total
DESC LIMIT 10') as $r)echo
'<tr><td>'.h($r['username']).'</td><td>'.(int)$r['total'].'</td></tr>';?></tbody></table></div></div><div
 class="panel"><h2>Action breakdown</h2><div class="table-
wrap"><table><thead><tr><th>Action</th><th>Count</th></tr></thead><tbody><?php
foreach($pdo->query('SELECT action,COUNT(*) AS total FROM audit_logs GROUP BY action ORDER BY total
DESC') as $r)echo
'<tr><td>'.h($r['action']).'</td><td>'.(int)$r['total'].'</td></tr>';?></tbody></table></div></div><?php
pageEnd(); ?>
```

users.php

```
<?php require_once __DIR__.'/includes/functions.php';requireRole('admin');$err='';if($_SERVER['REQUEST_ME
THOD']==='POST'){verifyCsrf();$action=$_POST['action']??'';if($action==='create'){$username=trim($_POST['
username']??'');$email=trim($_POST['email']??'');$name=trim($_POST['full_name']??'');$role=$_POST['role']
??'viewer';$password=$_POST['password']??'';if(!$username||!filter_var($email,FILTER_VALIDATE_EMAIL)||!$n
ame||strlen($password)<10||!in_array($role,['admin','researcher','viewer'],true))$err='Enter valid
details and a password of at least 10 characters.';else{try{$s=$pdo->prepare('INSERT INTO
users(username,email,password_hash,full_name,role) VALUES(?,?,?,?,?)');$s-
>execute([$username,$email,password_hash($password,PASSWORD_DEFAULT),$name,$role]);logAudit('USER_CREATED
','Created account '.$username);header('Location: users.php?message='.urlencode('User account
created.'));exit;}catch(Throwable $e){$err='Could not create user. Username or email may already exist.';
}}}elseif($action==='toggle'){$id=(int)$_POST['id'];if($id!==$_SESSION['user_id']){$pdo->prepare('UPDATE
users SET is_active=CASE WHEN is_active=1 THEN 0 ELSE 1 END WHERE
id=?')->execute([$id]);logAudit('USER_STATUS_CHANGED','Changed active status for user
#'.$id);}header('Location: users.php');exit;}}pageStart('User management');notice();if($err)echo '<div
class="alert danger">'.h($err).'</div>';?><div class="page-heading"><div><p class="eyebrow">ACCESS
GOVERNANCE</p><h1>User management</h1><p class="muted">Create accounts and manage role
assignments.</p></div></div><div class="panel"><h2>Create user</h2><form method="post" class="form-
grid"><input type="hidden" name="csrf" value="<?=h(csrfToken())?>"><input type="hidden" name="action"
value="create"><div><label>Full name</label><input name="full_name"
required></div><div><label>Username</label><input name="username"
required></div><div><label>Email</label><input type="email" name="email"
required></div><div><label>Temporary password (10+ chars)</label><input type="password" name="password"
minlength="10" required></div><div><label>Role</label><select name="role"><option
value="researcher">Researcher</option><option value="viewer">Viewer</option><option
value="admin">Administrator</option></select></div><div class="align-end"><button class="btn
primary">Create account</button></div></form></div><div class="panel"><h2>Registered accounts</h2><div
class="table-
wrap"><table><thead><tr><th>Name</th><th>Username</th><th>Email</th><th>Role</th><th>Status</th><th>Last
login</th><th>Action</th></tr></thead><tbody><?php foreach($pdo->query('SELECT * FROM users ORDER BY id')
 as $r){echo '<tr><td>'.h($r['full_name']).'</td><td>'.h($r['username']).'</td><td>'.h($r['email']).'</td
><td>'.h($r['role']).'</td><td>'.($r['is_active']?'Active':'Inactive').'</td><td>'.h($r['last_login']??'—
').'</td><td>';if($r['id']!=$_SESSION['user_id'])echo '<form method="post"><input type="hidden"
name="csrf" value="'.h(csrfToken()).'"><input type="hidden" name="action" value="toggle"><input
type="hidden" name="id" value="'.(int)$r['id'].'"><button class="btn small
secondary">'.($r['is_active']?'Deactivate':'Activate').'</button></form>';echo
'</td></tr>';}?></tbody></table></div></div><?php pageEnd(); ?>
```

config/database.php

```
<?php
// SQLite database bootstrap. Requires PHP PDO_SQLite extension.
$base = dirname(__DIR__);
if (!is_dir($base . '/storage')) mkdir($base . '/storage', 0700, true);
$pdo = new PDO('sqlite:' . $base . '/storage/rdms.sqlite');
$pdo->setAttribute(PDO::ATTR_ERRMODE, PDO::ERRMODE_EXCEPTION);
$pdo->setAttribute(PDO::ATTR_DEFAULT_FETCH_MODE, PDO::FETCH_ASSOC);
$pdo->exec('PRAGMA foreign_keys = ON');
$schema = [
"CREATE TABLE IF NOT EXISTS users (id INTEGER PRIMARY KEY AUTOINCREMENT, username TEXT UNIQUE NOT NULL,
email TEXT UNIQUE NOT NULL, password_hash TEXT NOT NULL, full_name TEXT NOT NULL, role TEXT NOT NULL
CHECK(role IN ('admin','researcher','viewer')), is_active INTEGER NOT NULL DEFAULT 1, created_at TEXT
```

```
DEFAULT CURRENT_TIMESTAMP, last_login TEXT)",
"CREATE TABLE IF NOT EXISTS research_data (id INTEGER PRIMARY KEY AUTOINCREMENT, title TEXT NOT NULL,
description TEXT, filename TEXT NOT NULL, original_filename TEXT NOT NULL, file_path TEXT NOT NULL,
file_size INTEGER, mime_type TEXT, uploaded_by INTEGER NOT NULL, project_code TEXT, created_at TEXT
DEFAULT CURRENT_TIMESTAMP, FOREIGN KEY(uploaded_by) REFERENCES users(id))",
"CREATE TABLE IF NOT EXISTS audit_logs (id INTEGER PRIMARY KEY AUTOINCREMENT, user_id INTEGER, username
TEXT, action TEXT NOT NULL, details TEXT, ip_address TEXT, user_agent TEXT, status TEXT DEFAULT
'success', created_at TEXT DEFAULT CURRENT_TIMESTAMP)",
"CREATE TABLE IF NOT EXISTS mfa_codes (id INTEGER PRIMARY KEY AUTOINCREMENT, user_id INTEGER NOT NULL,
code_hash TEXT NOT NULL, expires_at TEXT NOT NULL, used INTEGER DEFAULT 0, FOREIGN KEY(user_id)
REFERENCES users(id))",
"CREATE TABLE IF NOT EXISTS security_alerts (id INTEGER PRIMARY KEY AUTOINCREMENT, user_id INTEGER,
alert_type TEXT NOT NULL, message TEXT NOT NULL, severity TEXT DEFAULT 'medium', resolved INTEGER DEFAULT
 0, created_at TEXT DEFAULT CURRENT_TIMESTAMP, FOREIGN KEY(user_id) REFERENCES users(id))",
"CREATE TABLE IF NOT EXISTS login_attempts (id INTEGER PRIMARY KEY AUTOINCREMENT, username TEXT,
attempted_at TEXT DEFAULT CURRENT_TIMESTAMP, success INTEGER DEFAULT 0)"
];
foreach ($schema as $sql) $pdo->exec($sql);
$count = (int)$pdo->query('SELECT COUNT(*) FROM users')->fetchColumn();
if (!$count) {
  $seed = $pdo->prepare('INSERT INTO users(username,email,password_hash,full_name,role)
VALUES(?,?,?,?,?)');
  foreach ([['admin','admin@example.test','Admin@123','System
Administrator','admin'],['researcher1','researcher@example.test','Researcher@123','Researcher
One','researcher'],['viewer1','viewer@example.test','Viewer@123','Viewer One','viewer']] as $u)
$seed->execute([$u[0],$u[1],password_hash($u[2], PASSWORD_DEFAULT),$u[3],$u[4]]);
}
```

includes/functions.php

```
<?php
if (session_status() !== PHP_SESSION_ACTIVE) { session_name('RDMSSESSID'); session_start(); }
require_once __DIR__ . '/../config/database.php';
function h($v): string { return htmlspecialchars((string)$v, ENT_QUOTES, 'UTF-8'); }
function logAudit(string $action, string $details='', string $status='success', ?int $userId=null,
?string $username=null): void {
 global $pdo; $uid=$userId ?? ($_SESSION['user_id'] ?? null); $uname=$username ?? ($_SESSION['username']
?? 'guest');
 $s=$pdo->prepare('INSERT INTO audit_logs(user_id,username,action,details,ip_address,user_agent,status)
VALUES(?,?,?,?,?,?,?)');
 $s-
>execute([$uid,$uname,$action,$details,$_SERVER['REMOTE_ADDR']??'local',substr($_SERVER['HTTP_USER_AGENT'
]??'unknown',0,250),$status]);
}
function createSecurityAlert(?int $userId,string $type,string $message,string $severity='medium'): void {
 global $pdo; $s=$pdo->prepare('INSERT INTO security_alerts(user_id,alert_type,message,severity)
VALUES(?,?,?,?)'); $s->execute([$userId,$type,$message,$severity]); }
function requireLogin(): void { if (empty($_SESSION['user_id'])) { header('Location: login.php'); exit; }
 }
function requireRole($roles): void { requireLogin(); if (!in_array($_SESSION['role'],(array)$roles,true))
 { logAudit('UNAUTHORIZED_ACCESS','Attempted restricted page','failed'); header('Location:
dashboard.php?error=access_denied'); exit; } }
function csrfToken(): string { if (empty($_SESSION['csrf'])) $_SESSION['csrf']=bin2hex(random_bytes(32));
 return $_SESSION['csrf']; }
function verifyCsrf(): void { if ($_SERVER['REQUEST_METHOD']==='POST' &&
!hash_equals($_SESSION['csrf']??'', $_POST['csrf']??'')) { http_response_code(400); exit('Invalid request
 token. Return and try again.'); } }
function encryptFile(string $source,string $dest): void { $data=file_get_contents($source);
$key=hash('sha256', getenv('RDMS_ENCRYPTION_KEY') ?: 'local-demo-key-change-before-deployment', true);
$iv=random_bytes(16); $cipher=openssl_encrypt($data,'AES-256-CBC',$key,OPENSSL_RAW_DATA,$iv); if
($cipher===false || file_put_contents($dest,$iv.$cipher)===false) throw new RuntimeException('Could not
encrypt file.'); }
function decryptFile(string $path): string|false { $data=file_get_contents($path); if ($data===false ||
strlen($data)<17) return false; $key=hash('sha256', getenv('RDMS_ENCRYPTION_KEY') ?: 'local-demo-key-
change-before-deployment', true); return
openssl_decrypt(substr($data,16),'AES-256-CBC',$key,OPENSSL_RAW_DATA,substr($data,0,16)); }
```

```
function pageStart(string $title): void { $active=basename($_SERVER['PHP_SELF']); echo '<!doctype
html><html lang="en"><head><meta charset="utf-8"><meta name="viewport" content="width=device-
width,initial-scale=1"><title>'.h($title).' | Secure RDMS</title><link rel="stylesheet"
href="assets/css/style.css"></head><body><header class="topbar"><a class="brand"
href="dashboard.php">Secure <span>RDMS</span></a>'; if (!empty($_SESSION['user_id'])) { echo '<nav><a
href="dashboard.php">Dashboard</a><a href="files.php">Research Files</a>'; if
($_SESSION['role']==='admin') echo '<a href="audit.php">Audit Logs</a><a href="alerts.php">Security
Alerts</a><a href="reports.php">Reports</a><a href="users.php">Users</a>'; echo '</nav><div
class="identity">'.h($_SESSION['full_name']).'<small>'.h(ucfirst($_SESSION['role'])).'</small> <a
class="logout" href="logout.php">Logout</a></div>'; } echo '</header><main class="container">'; }
function pageEnd(): void { echo '</main><footer>Secure Research Data Management System · Academic
demonstration</footer></body></html>'; }
function notice(): void { if(isset($_GET['error'])) echo '<div class="alert
danger">'.h($_GET['error']==='access_denied'?'Access denied. Your role cannot open that
page.':$_GET['error']).'</div>'; if(isset($_GET['message'])) echo '<div class="alert
success">'.h($_GET['message']).'</div>'; }
```

assets/css/style.css

```
:root{--navy:#10233f;--blue:#2456a6;--cyan:#d9e8ff;--ink:#1d2939;--muted:#667085;--line:#e4e9f0;--
bg:#f4f7fb;--white:#fff;--green:#16845b;--red:#b42318}*{box-sizing:border-
box}body{margin:0;background:var(--bg);font:15px/1.5 Inter,Segoe UI,Arial,sans-
serif;color:var(--ink)}a{color:var(--blue);text-decoration:none}.topbar{height:auto;min-
height:76px;background:var(--navy);color:#fff;display:flex;align-items:center;gap:32px;padding:16px
max(24px,calc((100vw - 1180px)/2));flex-wrap:wrap}.brand{color:white;font-weight:800;font-
size:21px;letter-spacing:-.5px;white-space:nowrap}.brand span{color:#8fc0ff}.topbar
nav{display:flex;gap:20px;flex:1;flex-wrap:wrap}.topbar nav a{color:#d9e5f8;font-size:14px}.topbar nav
a:hover{color:white}.identity{display:flex;align-items:center;gap:10px;font-size:13px}.identity
small{background:#294466;padding:4px 8px;border-
radius:20px;color:#d9e5f8}.logout{color:#a9ccff}.container{max-width:1180px;margin:36px auto;padding:0
22px;min-height:calc(100vh - 160px)}.page-heading{display:flex;align-items:center;justify-content:space-
between;margin:0 0 26px;gap:20px}.page-heading h1{margin:2px 0 6px;font-size:32px;letter-
spacing:-1px;color:var(--navy)}.eyebrow{color:#5273a5;font-weight:800;font-size:11px;letter-
spacing:1.6px;margin:0 0 5px}.muted{color:var(--muted);margin:0}.role-chip{font-size:11px;letter-
spacing:.8px;font-weight:800;background:#e6efff;color:#2456a6;padding:8px 12px;border-radius:22px}.stats-
grid{display:grid;grid-template-columns:repeat(4,minmax(0,1fr));gap:16px;margin-bottom:22px}.stat-
card,.panel{background:white;border:1px solid var(--line);border-radius:14px;box-shadow:0 3px 12px
#18315308}.stat-card{padding:20px}.stat-card span{display:block;color:var(--muted);font-size:13px}.stat-
card strong{display:block;font-size:34px;letter-spacing:-1px;color:var(--navy);margin:7px 0}.stat-card
small{color:#8290a4}.panel{padding:22px;margin:0 0 22px}.panel h2{font-size:18px;margin:0 0
14px;color:var(--navy)}.panel-head{display:flex;align-items:center;justify-content:space-
between;gap:15px;margin-bottom:16px}.panel-head h2{margin-bottom:3px}.table-
wrap{overflow-x:auto}table{border-collapse:collapse;width:100%;font-size:13px;min-width:650px}th{text-
align:left;color:#667085;font-size:11px;text-transform:uppercase;letter-
spacing:.7px;background:#f8fafd}td,th{padding:13px 12px;border-bottom:1px solid #edf0f5;vertical-
align:middle}tbody tr:last-child td{border-bottom:0}.empty{text-
align:center;color:#7c8798;padding:30px}.status{display:inline-
block;background:#e3f7ed;color:#13754f;padding:4px 8px;border-radius:30px;font-size:11px;font-
weight:700}.status.failed{background:#fee4e2;color:#b42318}.btn{display:inline-flex;align-
items:center;justify-content:center;gap:8px;border:0;border-radius:8px;padding:11px 16px;font-
weight:700;font-size:13px;cursor:pointer}.btn.primary{background:var(--
blue);color:#fff}.btn.primary:hover{background:#194687}.btn.secondary{background:#eef3fa;color:#25466f}.b
tn.small{padding:7px 10px;font-size:12px}.btn.full{width:100%;margin-top:20px}.event-
row{display:flex;gap:12px;align-items:flex-start;padding:12px 0;border-top:1px solid #edf0f5}.event-
dot{width:9px;height:9px;border-radius:50%;background:#4981d4;margin-top:6px;flex-shrink:0}.event-row
strong{font-size:13px}.event-row p{margin:2px 0;color:var(--muted);font-size:13px}.event-row time{margin-
left:auto;color:#8290a4;font-size:11px;white-space:nowrap}.form-grid{display:grid;grid-template-
columns:1fr 1fr;gap:17px}.span-2{grid-column:span 2}label{display:block;font-size:13px;font-
weight:700;color:#344054;margin-bottom:7px}input,textarea,select{width:100%;border:1px solid
#cfd7e3;border-radius:8px;background:white;padding:11px 12px;font:inherit;font-
size:14px;color:var(--ink);outline:none}input:focus,textarea:focus,select:focus{border-color:#5b8bd5;box-
shadow:0 0 0 3px #dbeafe}input[type=file]{padding:9px}.filter-row{display:flex;gap:10px;margin-
bottom:18px}.filter-row input{max-width:330px}.filter-row select{max-width:180px}.severity{font-
size:11px;text-transform:uppercase;font-weight:800;padding:4px 8px;border-radius:20px}.severity.high{back
ground:#fee4e2;color:#b42318}.severity.medium{background:#fff0c2;color:#8a5b00}.severity.low{background:#
e0f2fe;color:#075985}.alert{padding:12px 14px;border-radius:9px;margin-bottom:18px;font-
size:13px}.alert.danger{background:#fff0ef;color:#9f231b;border:1px solid
```

#ffd2cf}.alert.success{background:#eaf8f0;color:#126b47;border:1px solid #c5ebd6}.auth-wrap{display:flex;justify-content:center;padding:28px 0 48px}.auth-card{width:100%;max-width:460px;background:white;border:1px solid var(--line);border-radius:18px;padding:36px;box-shadow:0 15px 45px #17345b12}.brand-mark{width:48px;height:48px;background:var(--navy);color:white;border-radius:13px;display:grid;place-items:center;font-weight:900;font-size:17px;margin-bottom:22px}.auth-card h1{font-size:28px;color:var(--navy);margin:4px 0 8px;letter-spacing:-.7px}.auth-card .muted{margin-bottom:24px}.auth-card label:not(:first-child){margin-top:16px}.demo-accounts{background:#f6f8fb;border:1px solid var(--line);border-radius:10px;padding:14px 16px;margin-top:22px;font-size:12px}.demo-accounts p{margin:5px 0;color:#526078}.demo-code{margin-top:18px;background:#eef5ff;border:1px dashed #8cb2e8;border-radius:10px;padding:14px;color:#244b7e}.demo-code strong{font-size:22px;letter-spacing:3px;margin-left:6px}.demo-code small{display:block;margin-top:5px;color:#526d91}footer{text-align:center;padding:24px;color:#8994a5;font-size:12px;border-top:1px solid #e8edf4}.align-end{display:flex;align-items:end}@media(max-width:850px){.topbar{gap:16px}.topbar nav{order:3;flex-basis:100%;gap:14px}.identity{margin-left:auto}.stats-grid{grid-template-columns:repeat(2,minmax(0,1fr))}}@media(max-width:560px){.container{margin:24px auto;padding:0 14px}.page-heading h1{font-size:27px}.stats-grid{grid-template-columns:1fr 1fr;gap:10px}.stat-card{padding:14px}.stat-card strong{font-size:28px}.panel{padding:15px}.form-grid{grid-template-columns:1fr}.span-2{grid-column:auto}.auth-card{padding:25px}.filter-row{flex-wrap:wrap}.identity{font-size:11px}}